

Compliance Gap Analysis Report

SAMA Cyber Security Framework
Prepared for: Al-Manara Secure Bank
Generated: 2026-07-29 13:45

Executive Summary

Status	Count	Percentage
Compliant	36	100.0%
Partially Compliant	0	0.0%
Non-Compliant	0	0.0%

Detailed Findings

Control	Domain	Status	Justification	Recommendation
3.1.1 Cyber Security Governance	Cybersecurity Governance and Leadership	Compliant	The company's policy clearly addresses the establishment of a cyber security committee, its charter, and the roles and responsibilities of its members, including the CISO. The policy also ensures the CISO has a Saudi nationality, is sufficiently qualified, and has a separate reporting line, budget, and staff performance evaluation.	-
3.1.2 Cyber Security Strategy	Cybersecurity Governance and Leadership	Compliant	The company's policy clearly addresses the control's requirements, including defining, approving, maintaining, and executing the cyber security strategy, aligning it with the bank's overall objectives, legal and regulatory compliance requirements, and the Banking Sector's cyber security strategy.	-
3.1.3 Cyber Security Policy	Cybersecurity Governance and Leadership	Compliant	The excerpts clearly and specifically address the control's requirements, including the definition, approval, and communication of the cyber security policy, its review process, and its support by detailed security standards and procedures.	-
3.1.4 Cyber Security Roles and Responsibilities	Cybersecurity Governance and Leadership	Compliant	The company's policy clearly and specifically addresses the control's requirements, including the responsibilities of the Board of Directors, Cyber Security Committee, senior management, CISO, internal audit, and all staff.	-

Control	Domain	Status	Justification	Recommendation
3.1.5 Cyber Security in Project Management	Cybersecurity Governance and Leadership	Compliant	The company's policy clearly addresses the control's requirements, including integrating cyber security into project management, including cyber security objectives in project objectives, participating in all project phases, performing risk assessments, registering and tracking cyber security risks, defining and allocating responsibilities, and performing independent cyber security reviews.	-
3.1.6 Cyber Security Awareness	Cybersecurity Governance and Leadership	Compliant	The excerpts clearly and specifically address the control's requirements, including defining, approving, and conducting a cyber security awareness program for staff, third parties, and customers, and evaluating its effectiveness.	-
3.1.7 Cyber Security Training	Cybersecurity Governance and Leadership	Compliant	The company policy clearly addresses the control's requirements, including providing specialist or security-related skills training to staff in relevant functional area categories, equipping staff with the skills and knowledge to securely operate the bank's information assets, and incorporating cyber security risk management into the project management methodology.	-
3.2.1 Cyber Security Risk Management	Cyber Security Risk Management and Compliance	Compliant	The company's policy clearly addresses the control's requirements, including defining, approving, and implementing a cyber security risk management process, aligning it with the enterprise risk management process, and involving business owners, IT specialists, and cyber security specialists in risk management activities.	-
3.2.1.1 Cyber Security Risk Identification	Cyber Security Risk Management and Compliance	Compliant	The company's policy clearly addresses the control's requirements, including performing cyber security risk identification, documenting identified risks in a central register, and addressing relevant information assets, threats, vulnerabilities, and existing controls.	-
3.2.1.2 Cyber Security Risk Analysis	Cyber Security Risk Management and Compliance	Compliant	The company's policy clearly addresses the control's requirements, including performing a cyber security risk analysis, evaluating the likelihood and potential business impact, and documenting the risk rating to prioritize treatment.	-

Control	Domain	Status	Justification	Recommendation
3.2.1.3 Cyber Security Risk Response	Cyber Security Risk Management and Compliance	Compliant	The company's policy clearly addresses all aspects of treating cyber security risks, including risk treatment options, documentation, acceptance, avoidance, transfer, mitigation, and residual risk sign-off, as well as documenting treatment actions in a risk treatment plan.	-
3.2.1.4 Cyber Risk Monitoring and Review	Cyber Security Risk Management and Compliance	Compliant	The excerpts clearly and specifically address the control's requirements, including tracking progress in accordance to treatment plan, implementing selected controls, and reviewing the design and effectiveness of revised or newly implemented controls.	-
3.2.2 Regulatory Compliance	Cyber Security Risk Management and Compliance	Compliant	The company's policy clearly addresses the control's requirements, including a formal process for ensuring compliance with regulatory requirements, periodic review, involvement of key representatives, and timely update of cyber security policy, standards, and procedures.	-
3.2.3 Compliance with (inter)national industry standards	Cyber Security Risk Management and Compliance	Compliant	The company policy clearly states compliance with PCI-DSS, EMV technical standard, and SWIFT Customer Security Controls Framework, which matches the control's requirements.	-
3.2.4 Cyber Security Review	Cyber Security Risk Management and Compliance	Compliant	The company policy clearly addresses the control's requirements, including periodic cyber security reviews, recording of review results, reporting to business owners, and follow-up reviews to check that identified issues are addressed.	-
3.2.5 Cyber Security Audits	Cyber Security Risk Management and Compliance	Compliant	The excerpts clearly show that cyber security audits are performed independently by Internal Audit, in accordance with generally accepted auditing standards and the SAMA Cyber Security Framework, following the bank's documented audit manual and annual audit plan.	-
3.3.1 Human Resources	Cyber Security Operations and Technology	Compliant	The excerpts clearly and specifically address the control's requirements, including defining, approving, and implementing cyber security requirements, monitoring and evaluating their effectiveness, and incorporating cyber security responsibilities and non-disclosure clauses within staff agreements.	-

Control	Domain	Status	Justification	Recommendation
3.3.2 Physical Security	Cyber Security Operations and Technology	Compliant	The excerpts clearly and specifically address the control's requirements, including defining, approving, and implementing the physical security process, monitoring its effectiveness, and including physical entry controls, monitoring and surveillance, protection of data centers and data rooms, environmental protection, and protection of information assets throughout their lifecycle.	-
3.3.3 Asset Management	Cyber Security Operations and Technology	Compliant	The excerpts clearly and specifically address the control's requirements, including defining, approving, implementing, monitoring, and evaluating the asset management process, maintaining a unified register, assigning ownership and custodianship, and including a continuous process for discovering new information assets.	-
3.3.4 Cyber Security Architecture	Cyber Security Operations and Technology	Compliant	The company's policy clearly defines, approves, and implements the cyber security architecture, monitors compliance, and includes all required elements such as qualified cyber security architects, security-by-design principle, and periodic review.	-
3.3.5 Identity and Access Management	Cyber Security Operations and Technology	Compliant	The company's policy clearly addresses all requirements of SAMA CSF Control 3.3.5, including defining, approving, and implementing the identity and access management policy, monitoring compliance, measuring effectiveness, and including all necessary details such as business requirements for access control, user access management, automation, centralization, multi-factor authentication, and privileged and remote access management.	-

Control	Domain	Status	Justification	Recommendation
3.3.6 Application Security	Cyber Security Operations and Technology	Compliant	The excerpts clearly and specifically address the control's requirements, including defining, approving, and implementing application cyber security standards, monitoring compliance, measuring and periodically evaluating effectiveness, following a secure SDLC, and including secure coding standards, segregation of duties, data protection, vulnerability and patch management, backup and recovery procedures, and periodic cyber security compliance review.	-
3.3.7 Change Management	Cyber Security Operations and Technology	Compliant	The company's policy clearly addresses all requirements of the control, including defining, approving, and implementing the change management process, monitoring compliance, measuring and periodically evaluating effectiveness, and including specific requirements such as impact assessment, security testing, approval by business owner and cyber security function, post-implementation review, and segregation of development, testing, and production environments.	-
3.3.8 Infrastructure Security	Cyber Security Operations and Technology	Compliant	The company's policy clearly defines, approves, and implements infrastructure security standards, monitors compliance, measures effectiveness, and periodically evaluates it, covering all instances of infrastructure in the main datacenter, disaster recovery site, and office locations.	-
3.3.9 Cryptography	Cyber Security Operations and Technology	Compliant	The excerpts clearly and specifically address the control's requirements, including defining, approving, and implementing a cryptographic security standard, monitoring compliance, measuring effectiveness, and including an overview of approved cryptographic solutions, circumstances of use, and key management lifecycle.	-

Control	Domain	Status	Justification	Recommendation
3.3.10 Bring Your Own Device (BYOD)	Cyber Security Operations and Technology	Compliant	The company's policy clearly addresses the control's requirements, including defining, approving, and implementing a BYOD cyber security standard, monitoring compliance, measuring effectiveness, and including user responsibilities, restrictions, and consequences, containerization, regulation of mobile applications, and MDM.	-
3.3.11 Secure Disposal of Information Assets	Cyber Security Operations and Technology	Compliant	The company's policy clearly addresses all requirements of the control, including defining, approving, and implementing a secure disposal standard and procedure, monitoring compliance, measuring and evaluating effectiveness, disposing of information assets in accordance with legal and regulatory requirements, using non-retrievable destruction techniques, and ensuring third-party providers comply with the standard.	-
3.3.12 Payment Systems	Cyber Security Operations and Technology	Compliant	The excerpts clearly and specifically address the control's requirements, mentioning the definition, approval, implementation, and monitoring of a cyber security standard for payment systems, as well as the periodic evaluation of its effectiveness.	-
3.3.13 Electronic Banking Services	Cyber Security Operations and Technology	Compliant	The company's policy clearly addresses the control's requirements, including defining, approving, implementing, and monitoring a cyber security standard for electronic banking services, and ensuring the effectiveness of this standard is measured and periodically evaluated.	-
3.3.14 Cyber Security Event Management	Cyber Security Operations and Technology	Compliant	The excerpts clearly and specifically address the control's requirements, including defining, approving, and implementing a security event management process, measuring its effectiveness, and supporting it with a security event monitoring standard.	-
3.3.15 Cyber Security Incident Management	Cyber Security Operations and Technology	Compliant	The company's policy clearly addresses all requirements of the control, including defining, approving, and implementing a cyber security incident management process, measuring its effectiveness, and addressing various aspects such as incident classification, handling, and reporting.	-

Control	Domain	Status	Justification	Recommendation
3.3.16 Threat Management	Cyber Security Operations and Technology	Compliant	The excerpts clearly and specifically address the control's requirements, including defining, approving, and implementing the threat intelligence management process, using multiple reliable sources, measuring and periodically evaluating its effectiveness, and including a defined methodology to analyze threat information.	-
3.3.17 Vulnerability Management	Cyber Security Operations and Technology	Compliant	The company's policy clearly addresses all requirements of the control, including defining, approving, and implementing a vulnerability management process, measuring and evaluating its effectiveness, and including all necessary details such as frequency of scans, classification of vulnerabilities, and patch management.	-
3.4.1 Contract and Vendor Management	Third Party Cyber Security	Compliant	The excerpts clearly and specifically address the control's requirements, including defining, approving, implementing, and communicating cyber security requirements within the contract and vendor management processes, monitoring compliance, measuring effectiveness, and covering all the specified requirements for contract and vendor management.	-
3.4.2 Outsourcing	Third Party Cyber Security	Compliant	The excerpts clearly and specifically address the control's requirements, including defining, approving, implementing, and communicating cyber security controls within the outsourcing policy and process, measuring and periodically evaluating compliance, and involving the cyber security function and obtaining SAMA's prior approval.	-
3.4.3 Cloud Computing	Third Party Cyber Security	Compliant	The excerpts clearly address the control's requirements, including defining, implementing, and monitoring cyber security controls within the cloud computing policy, obtaining SAMA approval, conducting risk assessments, and including specific cyber security requirements in contracts.	-